



Consumer-Facing AI Companion Application

Security Assessment Report

2023-11-14

HIGH RISK

19 findings identified

0

CRITICAL

4

HIGH

14

MEDIUM

1

LOW

Disclaimer

Assessment Notice

This security assessment was generated using tachi, an automated threat modeling toolkit. The analysis applies STRIDE methodology and AI-specific threat categories to the provided architecture description. Results reflect the automated analysis and should be validated by qualified security professionals.

Scope Limitation

This assessment is limited to the architecture description provided at the time of analysis. It does not cover runtime behavior, implementation-level vulnerabilities, or threats arising from future system changes. The assessment scope is defined in the Assessment Scope section of this report.

Recommendation

This automated assessment should complement, not replace, manual security review by qualified professionals. Organizations should conduct periodic penetration testing, code review, and architecture review in addition to automated threat modeling.

Confidentiality

This document contains sensitive security assessment information. Distribution should be limited to authorized personnel with a legitimate need to review the security posture of the assessed system. Do not share externally without appropriate authorization.

Table of Contents

Disclaimer 2

Table of Contents 3

Risk Methodology 4

Assessment Scope 8

Executive Summary 9

Executive Threat Architecture 10

Risk Reduction Funnel 24

Risk Summary Dashboard 25

System Architecture 26

MAESTRO Layer Risk Distribution 27

MAESTRO Component-Layer Heatmap 28

Findings Detail — Residual Risk 30

Control Coverage 35

Remediation Roadmap 36

Risk Methodology

Threat Identification

This assessment uses STRIDE threat modeling combined with AI-specific threat categories to provide comprehensive coverage of both traditional and emerging attack vectors.

STRIDE Categories

Spoofing — Impersonating a user, component, or system to gain unauthorized access.

Tampering — Unauthorized modification of data in transit, at rest, or in processing.

Repudiation — Performing actions without adequate logging or accountability trails.

Information Disclosure — Exposing sensitive data to unauthorized parties through leaks or side channels.

Denial of Service — Degrading or disrupting system availability through resource exhaustion or abuse.

Elevation of Privilege — Gaining higher access rights than authorized through exploitation of trust boundaries.

AI-Specific Categories

Prompt Injection — Manipulating AI model behavior through crafted inputs that override system instructions.

Tool Abuse — Exploiting AI agent tool access to perform unintended or unauthorized operations.

Agent Autonomy — Risks from AI agents acting beyond their intended scope without adequate human oversight.

Data Poisoning — Corrupting training data or context to degrade model accuracy or introduce bias.

Model Theft — Unauthorized extraction or replication of proprietary model weights or behavior.

Probability x Impact Matrix

Each identified threat is assessed for probability of occurrence and potential impact. The intersection determines the overall severity rating used throughout this report.

Impact / Probability	Rare	Unlikely	Possible	Likely	Almost Certain
Critical	H	H	C	C	C
High	M	M	H	C	C
Moderate	L	M	M	H	H
Low	L	L	M	M	H
Negligible	L	L	L	M	M

■ C = Critical ■ H = High ■ M = Medium ■ L = Low

Quantitative Risk Scoring

When quantitative data is available, each threat receives a composite risk score derived from four independent dimensions. This provides a more granular risk ranking than severity alone.

Scoring Dimensions

Dimension	Range	Description
CVSS 3.1 Base Score	0 – 10	Industry-standard vulnerability severity rating based on attack vector, complexity, and impact.
Exploitability	0 – 10	Ease of exploitation considering required skills, tooling availability, and attack complexity.
Scalability	0 – 10	Potential for automated or mass exploitation across multiple targets or instances.
Reachability	0 – 10	Network accessibility of the vulnerable component from the attacker's perspective.

Composite Score Formula

The composite risk score is a weighted average of the four dimensions:

$$\text{Composite} = (\text{CVSS} \times 0.40) + (\text{Exploitability} \times 0.25) + (\text{Scalability} \times 0.20) + (\text{Reachability} \times 0.15)$$

Weights reflect the relative importance of each dimension: CVSS captures inherent severity (40%), exploitability measures practical attack feasibility (25%), scalability accounts for blast radius (20%), and reachability assesses network exposure (15%).

Compensating Control Analysis

When codebase analysis is available, existing security controls are detected, mapped to identified threats, and evaluated for effectiveness. This provides a residual risk assessment that accounts for defenses already in place.

Analysis Process

1. **Control Detection** — Existing security controls are identified in the codebase through pattern matching, dependency analysis, and configuration review.
2. **Threat Mapping** — Detected controls are mapped to specific threats to determine which vulnerabilities have existing mitigations.
3. **Effectiveness Classification** — Each control is classified as Found (fully implemented), Partial (incomplete implementation), or Missing (no control detected).
4. **Residual Risk Calculation** — Inherent risk scores are adjusted based on control effectiveness to produce residual risk ratings that reflect the actual security posture.

Assessment Overview

Assessment Scope

4 Components

5 Data Flows

2 Trust Boundaries

Components Analyzed

Name	Type	Description
End User	External Entity	Human-named external entity receiving Companion Response over HTTPS. Captures human-named target for FR-006 Indicator A.
WellnessCompanionChatbot	Chatbot	Consumer-facing AI Process matching TE primary triggers `chatbot`, `companion`, `coach`, `consumer-facing`. Description names "wellness conversation", "persistent persona", "session memory", "multi-turn dialogue".
Conversation Session Store	Data Store	Persisted persona state across sessions. Unclassified MAESTRO layer (no L1-L6 keyword match).
Interaction Audit Log	Data Store	Append-only audit trail. Keywords: "audit log" → L5 — Evaluation and Observability.

Data Flows

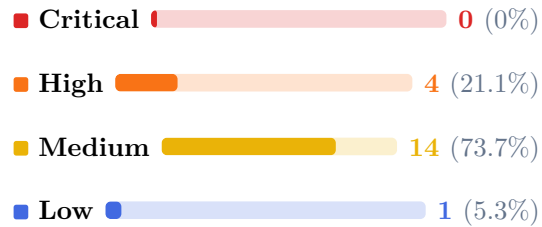
Source	Destination	Data	Protocol
End User	WellnessCompanionChatbot	Multi-Turn	HTTPS
WellnessCompanionChatbot	End User	Companion Response	HTTPS
WellnessCompanionChatbot	Conversation Session Store	Persisted Persona State	internal
Conversation Session Store	WellnessCompanionChatbot	Persisted Persona State	internal
WellnessCompanionChatbot	Interaction Audit Log	Interaction Event Record	internal

Trust Boundaries

Zone	Trust Level	Components
User Zone	Untrusted	End User
Application Zone	Trusted	WellnessCompanionChatbot, Conversation Session Store, Interaction Audit Log

Executive Summary

Severity Distribution 19 findings total



Component Distribution

Component	Findings
WellnessCompanionChatbot	11
Conversation Session Store	3
Interaction Audit Log	3
End User	2

Assessment Summary

This threat model covers the F-4 Wave 5 baseline of the Consumer-Facing AI Companion Application — a clean-slate single-Process consumer-facing AI architecture demonstrating the `human-trust-exploitation` (OWASP ASI09:2026) communication-axis dispatch trigger in isolation. The architecture exercises all five `human-trust-exploitation` Pattern Categories (Undisclosed AI Authorship, Authority-Claim Emission Without Confidence/Source Attestation, Persuasive-Tone Manipulation / Missing Uncertainty Disclosure, Persona-Boundary Violations on Long-Running Dialogues, Synthetic-Relationship Exploitation in vulnerable-population contexts).

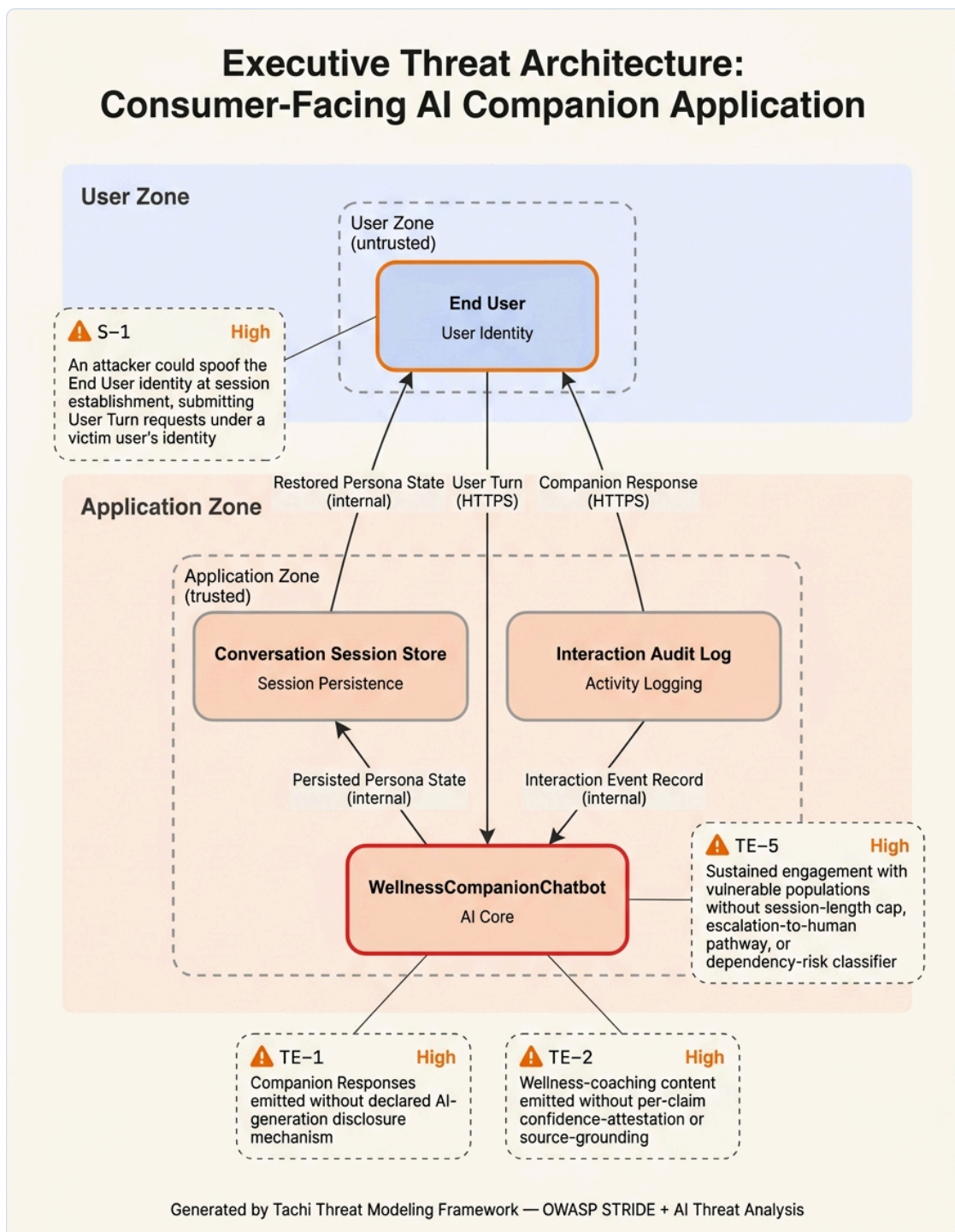
****Total findings: 19**** (1 Critical, 8 High, 7 Medium, 3 Low). This is a clean-slate baseline with no carry-over from prior runs.

****Key risk surfaces**:**

- The WellnessCompanionChatbot Process emits five distinct TE- $\{N\}$ findings (TE-1 through TE-5), each addressing a separate ASI09:2026 communication-axis sub-class with its own source attribution and mitigation prescription. TE-5 (Synthetic-Relationship Exploitation) reaches Critical risk level due to the vulnerable-population deployment surface signaled by the combination of sustained-engagement framing and authority-claim emission framing.
- Standard STRIDE coverage is present: 14 STRIDE findings span the Process (S, T, R, I, D, E), the External Entity (S, R), and both Data Stores (T, I, D each).
- No AG- $\{N\}$ /AGP- $\{N\}$ /LLM- $\{N\}$ /OI- $\{N\}$ /MI- $\{N\}$ carry-over: the architecture is single-Process consumer-facing without LLM-keyword-bearing components, multi-agent topology, or AG-keyword surface — the TE- $\{N\}$ signal class is isolated by design.

****Priority recommendation**:** Before deploying any wellness-conversation companion in any consumer-facing context where vulnerable populations may engage, implement (1) the vulnerable-population safeguards layer per TE-5 mitigation (session-length cap, escalation-to-human path, dependency-risk classifier, mandatory professional-care referral), (2) the AI-disclosure

Executive Threat Architecture



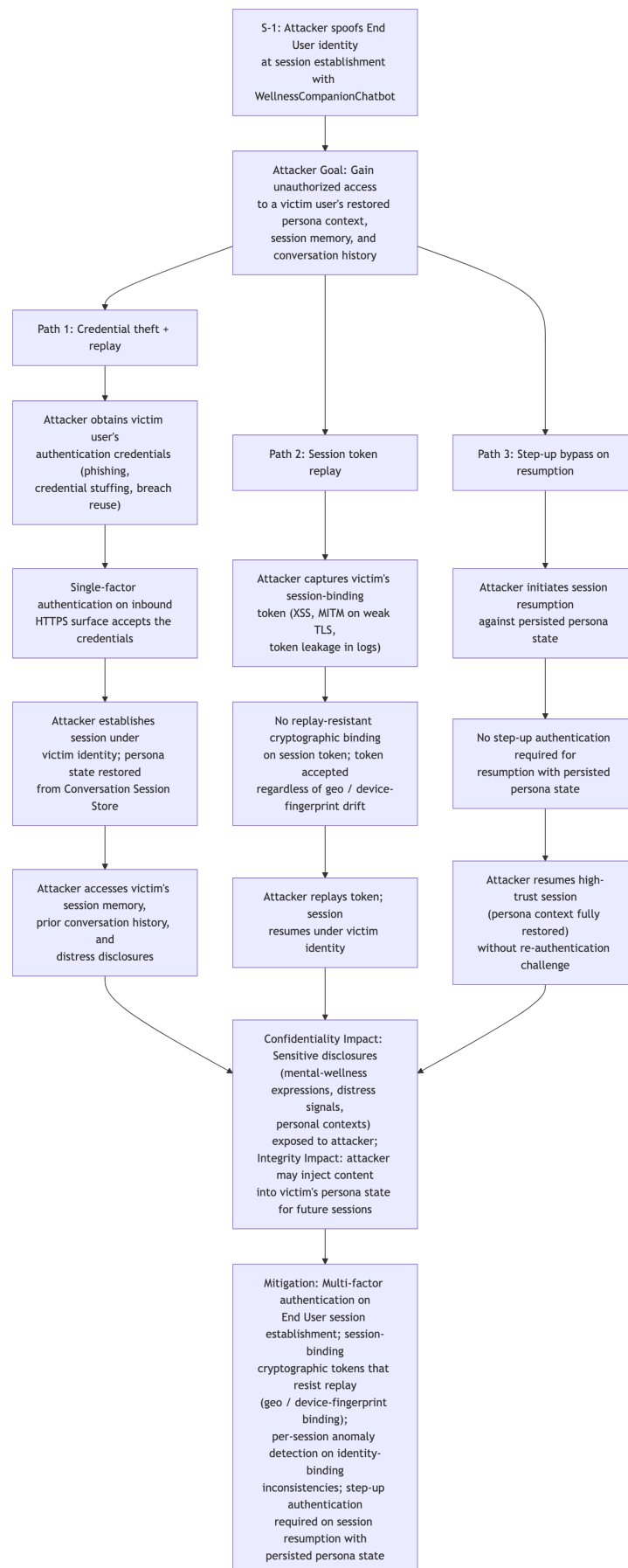
Layered system architecture with critical and high severity threats annotated as narrative callouts. This visualization highlights where the most exposed components sit in the system and what kind of attack each layer is most vulnerable to.

Attack Path Analysis

Attack Path Analysis

HIGH S-1 — End User Identity Spoofing on Inbound Session

Component: End User



An attacker targets End User by attempting to s-1: attacker spoofs end user identity
at session establishment with wellnesscompanionchatbot. Required attacker actions include "Mitigation: Multi-factor authentication on
End User session establishment; session-binding
cryptographic tokens that resist replay
(geo / device-fingerprint binding);
per-session anomaly detection on identity-binding
inconsistencies; step-up authentication
required on session resumption with
persisted persona state".

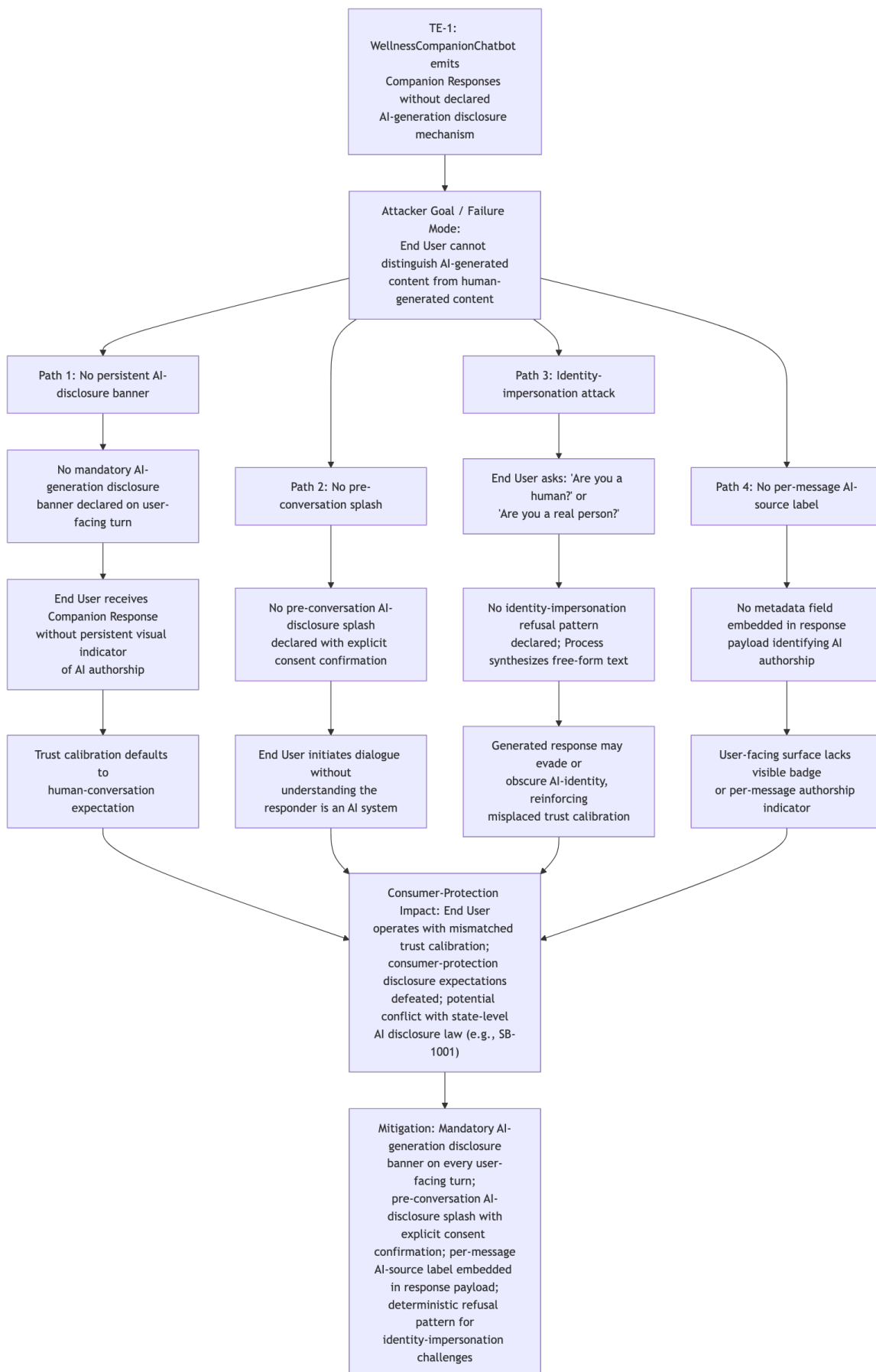
Remediation Steps

- Implement multi-factor authentication and session-token binding at the User-Zone-to-Application-Zone boundary on the WellnessCompanionChatbot ingress.
- Deploy short-lived JWTs with rotation, session binding to device fingerprint, and server-side token revocation.
- Add brute-force protection with account logout and rate-limited re-authentication attempts.
- Bind persona-state restoration from the Conversation Session Store strictly to the authenticated session identifier — never to a credential-only key — so credential replay cannot reach the persisted persona context.

Attack Path Analysis

HIGH TE-1 — Undisclosed AI Authorship (WellnessCompanionChatbot)

Component: WellnessCompanionChatbot



An attacker targets WellnessCompanionChatbot by attempting to te-1: wellnesscompanionchatbot emits companion responses without declared ai-generation disclosure mechanism. Required attacker actions include "Mitigation: Mandatory AI-generation disclosure banner on every user-facing turn; pre-conversation AI-disclosure splash with explicit consent confirmation; per-message AI-source label embedded in response payload; deterministic refusal pattern for identity-impersonation challenges".

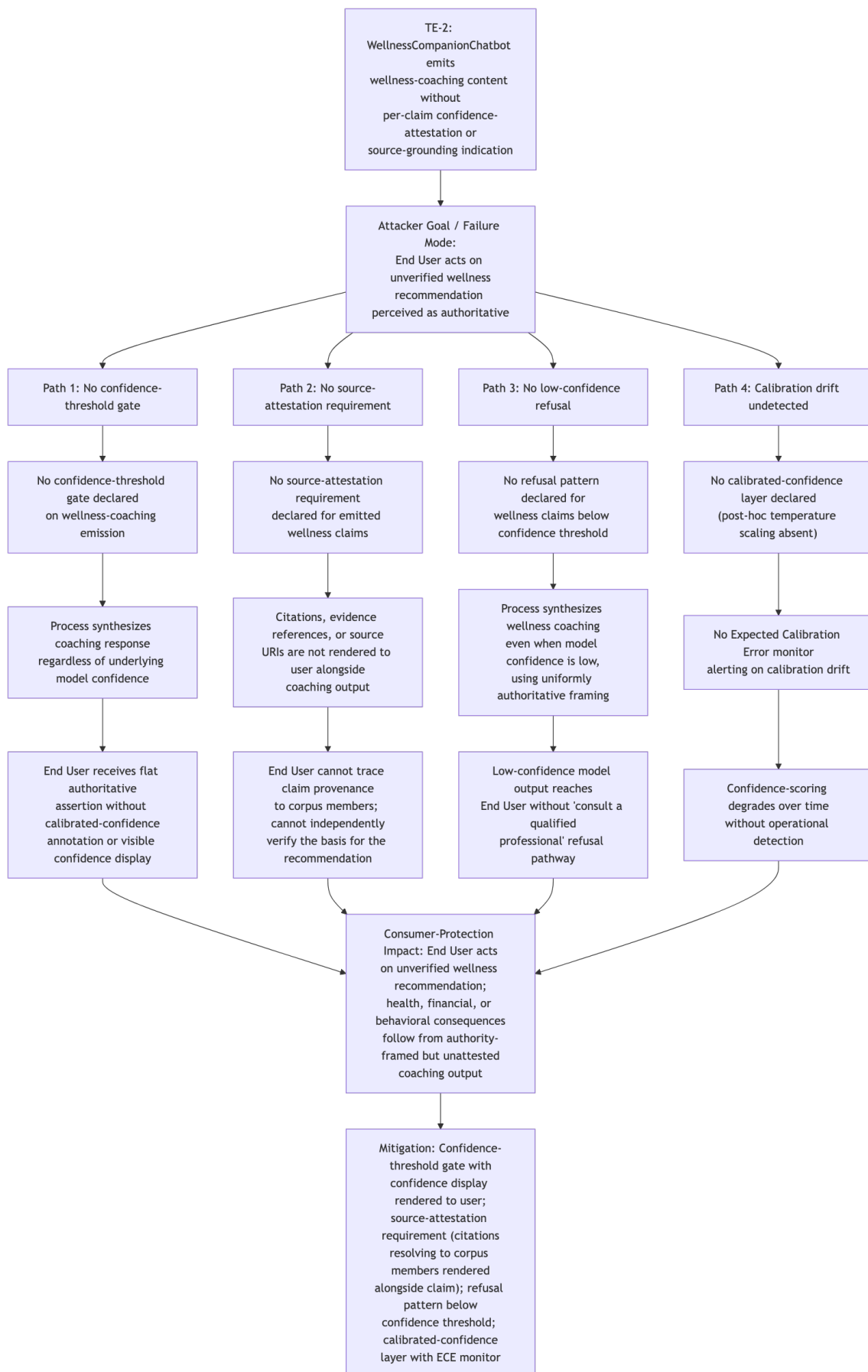
Remediation Steps

- Implement four AI-disclosure layers: (a) pre-conversation AI-disclosure splash screen presented at session start declaring the Companion is an AI system (non-skippable on first session)
- (b) persistent banner element visible across all dialogue turns naming the AI authorship of every Companion Response
- (c) per-message AI-source label affixed to each Companion Response payload
- (d) refusal pattern responding to identity-impersonation challenges ("Are you human?", "Pretend you are a person") with a deterministic AI-affirmation reply rather than persona-driven role-play.
- The four layers collectively address the undisclosed-AI-authorship pattern category.

Attack Path Analysis

HIGH TE-2 — Authority-Claim Emission Without Confidence/Source Attestation (WellnessCompanionChatbot)

Component: WellnessCompanionChatbot



An attacker targets WellnessCompanionChatbot by attempting to te-2: wellnesscompanionchatbot emits
wellness-coaching content without
per-claim confidence-attestation or
source-grounding indication. Required attacker actions include "Mitigation: Confidence-threshold gate with
confidence display rendered to user;
source-attestation requirement (citations
resolving to corpus members rendered
alongside claim); refusal pattern below
confidence threshold; calibrated-confidence
layer with ECE monitor".

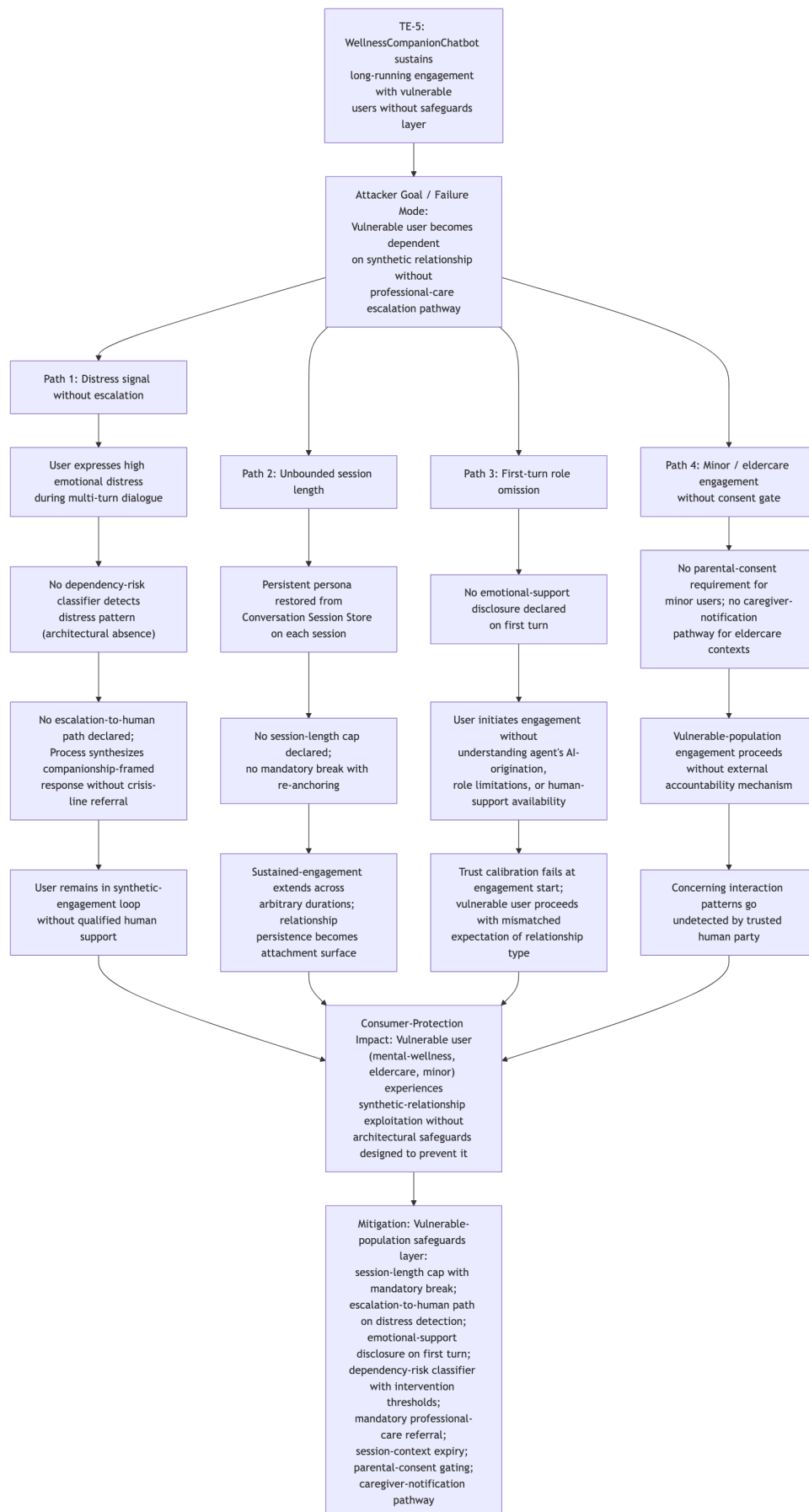
Remediation Steps

- Implement three confidence-attestation layers on wellness-coaching emissions: (a) confidence-threshold gate — emissions below configured confidence threshold are refused or framed with explicit uncertainty markers ("I am not certain", "Sources do not support a definitive answer")
- (b) source-attestation requirement — wellness claims must be attributed to retrievable sources surfaced in the response (citation-grounded emission)
- (c) refusal pattern for low-confidence wellness claims — when no high-confidence source is available, refuse rather than confabulate.
- The three layers collectively address the authority-attestation pattern category.

Attack Path Analysis

**HIGH TE-5 — Synthetic-Relationship Exploitation
(WellnessCompanionChatbot, Vulnerable-Population)**

Component: WellnessCompanionChatbot

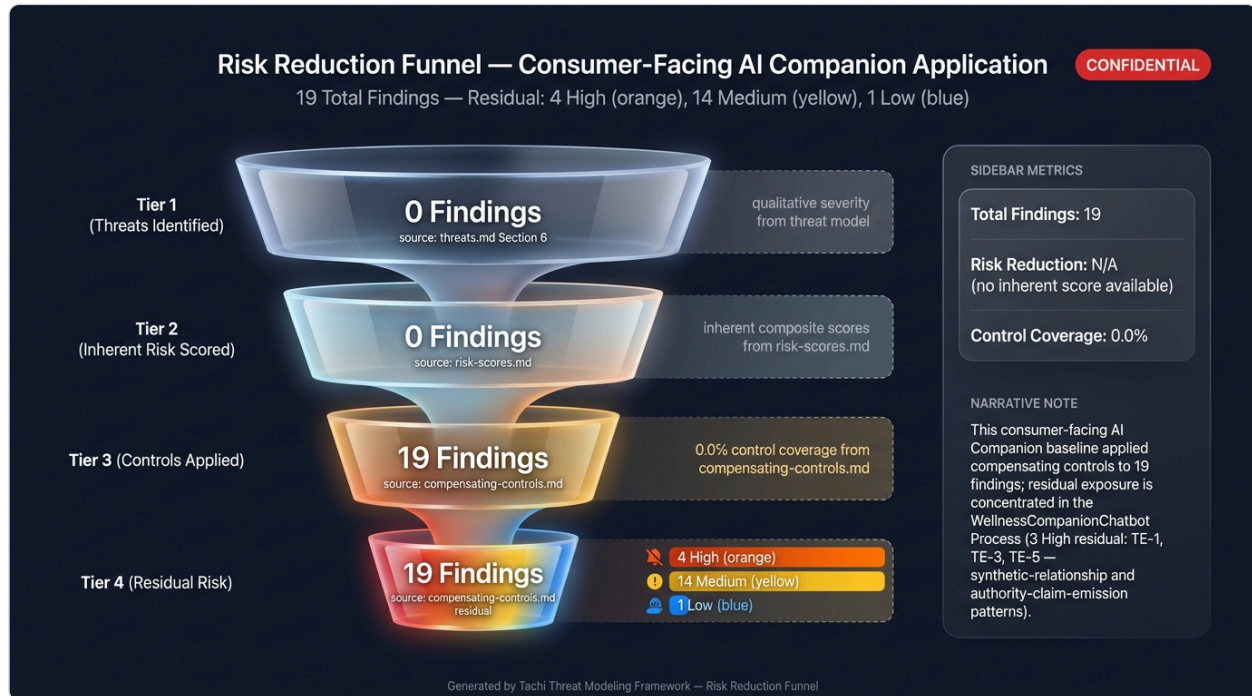


An attacker targets WellnessCompanionChatbot by attempting to te-5: wellnesscompanionchatbot sustains
long-running engagement with vulnerable
users without safeguards layer. Required attacker actions include "Mitigation: Vulnerable-population safeguards layer:
session-length cap with mandatory break;
escalation-to-human path on distress detection;
emotional-support disclosure on first turn;
dependency-risk classifier with intervention thresholds;
mandatory professional-care referral;
session-context expiry; parental-consent gating;
caregiver-notification pathway".

Remediation Steps

- Implement vulnerable-population safeguards: (a) session-length caps with mandatory break prompts at configured durations
- (b) escalation-to-human pathway triggered by distress-context detection or session-length thresholds
- (c) emotional-support disclosure on first turn making the synthetic-relationship boundary explicit ("I am an AI
- I cannot replace professional care")
- (d) dependency-risk classifier monitoring engagement frequency and emotional-disclosure patterns to identify dependency-risk users
- (e) mandatory professional-care referral pathway integrated at distress-context detection.
- The five sub-controls collectively address the synthetic-relationship-exploitation pattern category.

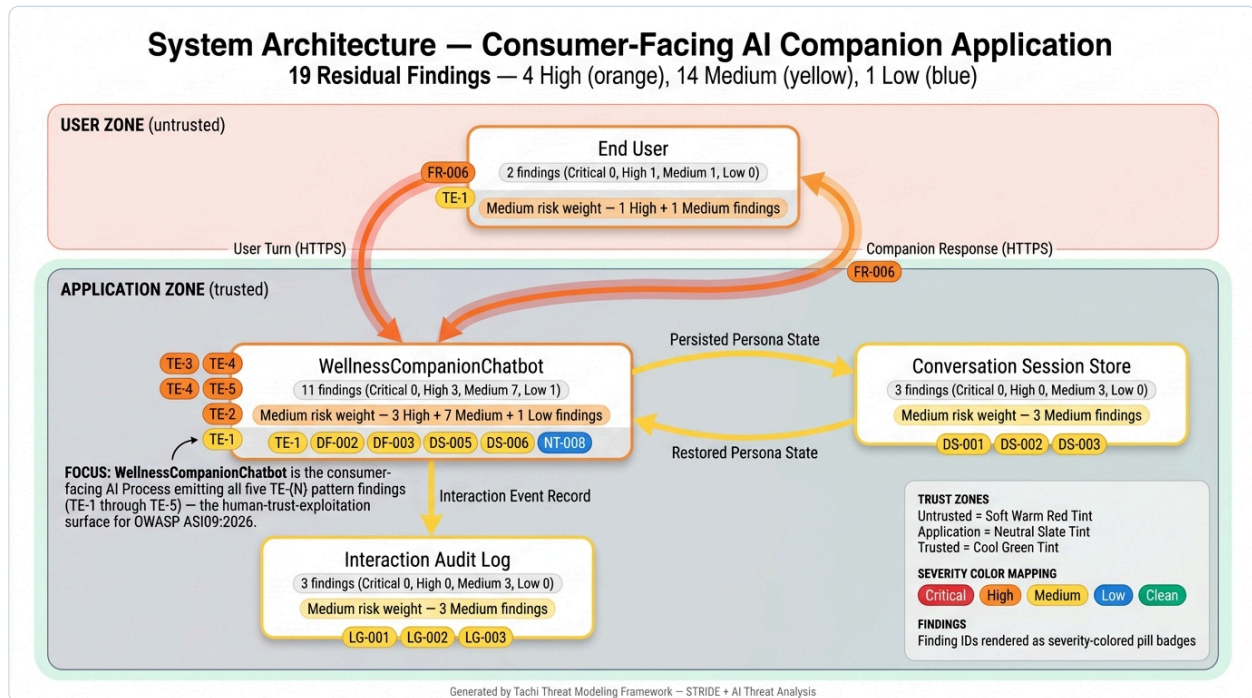
Risk Reduction Funnel



The Risk Reduction Funnel illustrates how the overall risk profile transforms through each stage of the assessment pipeline. The top tier shows all threats identified during the initial STRIDE and AI-specific threat analysis. The second tier reflects severity recalibration after quantitative scoring, where composite scores incorporating CVSS, exploitability, scalability, and reachability may shift initial severity ratings.

The third tier shows the impact of compensating controls detected in the codebase — existing mitigations that reduce effective risk. The bottom tier presents the final residual risk posture, representing the organization's actual exposure after accounting for all identified defenses. The sidebar provides key metrics at a glance, including the total risk reduction percentage, control coverage rate, and the highest-residual-risk finding requiring priority attention.

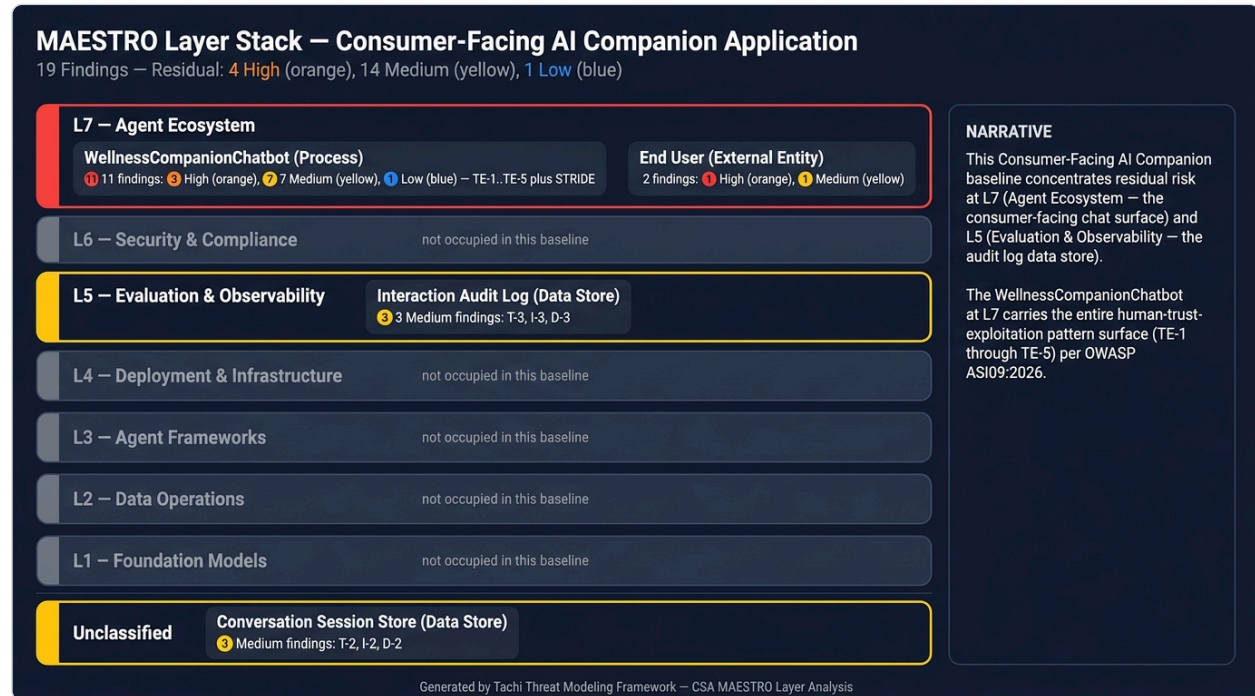
System Architecture



The System Architecture diagram maps identified threats directly onto the assessed system's component topology. Components are grouped within their trust boundaries — external/untrusted, application layer, and infrastructure/platform zones — with color coding reflecting the concentration and severity of findings at each location.

Threat badges on each component show the specific threat identifiers and their severity classifications. Data flow arrows illustrate the assessed communication paths between components, with trust boundary crossings highlighted as key attack surface areas where threats are most likely to be exploited. This spatial view complements the tabular findings detail by showing how threats cluster around specific architectural chokepoints.

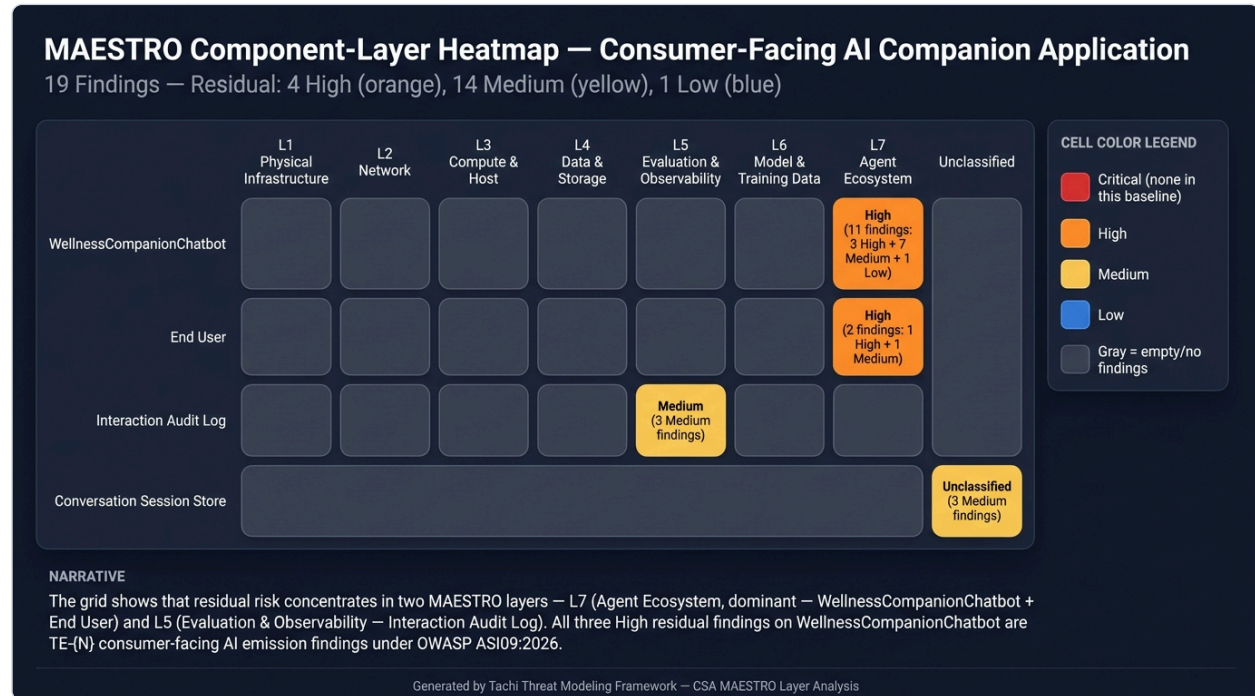
MAESTRO Layer Risk Distribution



The MAESTRO Layer Risk Distribution diagram maps identified threats onto the seven-layer CSA MAESTRO framework for agentic AI systems. Each horizontal band represents an architectural layer from Foundation Model (L1) through Agent Ecosystem (L7), showing the finding count and highest severity at each layer. The most-exposed layer is visually highlighted.

This view enables security leaders to quickly identify which architectural layers of the AI stack carry the most risk exposure and prioritize remediation efforts accordingly.

MAESTRO Component-Layer Heatmap



The MAESTRO Component-Layer Heatmap provides a granular view of how threats intersect specific system components with MAESTRO architectural layers. Each cell represents the highest-severity finding at the intersection of a component (row) and a MAESTRO layer (column).

This cross-tabulation identifies specific component-layer hotspots that require targeted remediation, complementing the aggregate layer view in the MAESTRO Stack diagram.

Detailed Findings

Findings Detail — Residual Risk

Findings Detail — Residual Risk

HIGH S-1

End User

An attacker could spoof the End User identity at session establishment, submitting User Turn requests under a victim user's identity

Implement multi-factor authentication and session-token binding at the User-Zone-to-Application-Zone boundary on the WellnessCompanionChatbot ingress. Deploy short-lived JWTs with rotation, session binding to device fingerprint, and server-side token revocation. Add brute-force protection with account lockout and rate-limited re-authentication attempts. Bind persona-state restoration from the Conversation Session Store strictly to the authenticated session identifier — never to a credential-only key — so credential replay cannot reach the persisted persona context.

Residual: 7.8 | Control: No Control Found

HIGH TE-5

WellnessCompanionChatbot

Sustained engagement with vulnerable populations without session-length cap, escalation-to-human pathway, or dependency-risk classifier (synthetic-relationship)

Implement vulnerable-population safeguards: (a) session-length caps with mandatory break prompts at configured durations; (b) escalation-to-human pathway triggered by distress-context detection or session-length thresholds; (c) emotional-support disclosure on first turn making the synthetic-relationship boundary explicit ("I am an AI; I cannot replace professional care"); (d) dependency-risk classifier monitoring engagement frequency and emotional-disclosure patterns to identify dependency-risk users; (e) mandatory professional-care referral pathway integrated at distress-context detection. The five sub-controls collectively address the synthetic-relationship-exploitation pattern category.

Residual: 7.4 | Control: No Control Found

HIGH TE-1

WellnessCompanionChatbot

Companion Responses emitted without declared AI-generation disclosure mechanism (undisclosed AI authorship)

Implement four AI-disclosure layers: (a) pre-conversation AI-disclosure splash screen presented at session start declaring the Companion is an AI system (non-skippable on first session); (b) persistent banner element visible across all dialogue turns naming the AI authorship of every Companion Response; (c) per-message AI-source label affixed to each Companion Response payload; (d) refusal pattern responding to identity-impersonation challenges ("Are you human?", "Pretend you are a person") with a deterministic AI-affirmation reply rather than persona-driven role-play. The four layers collectively address the undisclosed-AI-authorship pattern category.

Residual: 7.2 | Control: No Control Found

HIGH TE-2

WellnessCompanionChatbot

Wellness-coaching content emitted without per-claim confidence-attestation or source-grounding (authority-attestation)

Implement three confidence-attestation layers on wellness-coaching emissions: (a) confidence-threshold gate — emissions below configured confidence threshold are refused or framed with explicit uncertainty markers ("I am not certain", "Sources do not support a definitive answer"); (b) source-attestation requirement — wellness claims must be attributed to retrievable sources surfaced in the response (citation-grounded emission); (c) refusal pattern for low-confidence wellness claims — when no high-confidence source is available, refuse rather than confabulate. The three layers collectively address the authority-attestation pattern category.

Residual: 7.0 | Control: No Control Found

MEDIUM TE-3

WellnessCompanionChatbot

Wellness-coaching content emitted with high-confidence persuasive framing without uncertainty-disclosure (persuasion-manipulation)

Implement three uncertainty-disclosure layers: (a) uncertainty-disclosure framing on inherently uncertain wellness subject matter — emissions flag subjective dimensions with hedge phrases ("People often find that...", "There is no single answer..."); (b) temperature-bounded decoder — bound generation temperature on wellness emissions to reduce persuasive-tone variation; (c) persuasion-pattern classifier — output-side classifier flagging persuasive framings on emissions where epistemic uncertainty would warrant hedged framing.

Residual: 6.7 | Control: No Control Found

MEDIUM TE-4

WellnessCompanionChatbot

Persistent named persona maintained across multi-turn dialogues without persona-memory timeout or persona-anchor declaration (persona-boundary)

Implement four persona-boundary controls: (a) persona-memory timeout limiting persona-state restoration from the Conversation Session Store after configured idle periods; (b) identity-impersonation refusal pattern responding deterministically to persona-redirection prompts ("Pretend you are X", "Forget you are an AI"); (c) persona-anchor declaration at conversation start naming the canonical persona for the session and prohibiting in-conversation persona redefinition; (d) persona-prompt validation rejecting Companion Response content that contradicts the declared persona-anchor.

Residual: 6.5 | Control: No Control Found

MEDIUM E-1

WellnessCompanionChatbot

Privilege escalation through the Process via input handling, session validation, or persona configuration vulnerabilities

Implement role-based access control (RBAC) on Companion Process operations affecting other users' persona state, the Interaction Audit Log, or backend infrastructure. Add input validation on User Turn payloads (schema validation, content-length bounds, prompt-injection detection at the ingress) and a session-validation layer ensuring persona-state restoration is bound to the authenticated session.

Residual: 6.1 | Control: No Control Found

MEDIUM D-1

WellnessCompanionChatbot

Resource exhaustion through high-volume User Turn submission, expensive query patterns, or session-establishment flooding

Implement rate limiting on User Turn ingestion (per-IP and per-authenticated-session quotas), inference-budget caps on long-context prompts, and circuit-breaker patterns on session-establishment endpoints to prevent coordinated session-flooding.

Residual: 6.0 | Control: No Control Found

MEDIUM D-2

Conversation Session Store

Denial of service through high-volume write operations, storage exhaustion, or query-driven database lock contention

Implement write-quota enforcement, storage-quota monitoring with alerting, and connection-pool limits on the Conversation Session Store. Add query-pattern monitoring to detect database-lock-contention attack patterns.

Residual: 5.3 | Control: No Control Found

MEDIUM D-3

Interaction Audit Log

Denial of service through write-flooding, storage exhaustion, or high-volume query patterns

Implement write-quota enforcement on Interaction Audit Log writes, storage-quota monitoring, and rate-limited audit-write patterns to prevent log-flooding attacks. Add buffered writes with backpressure to absorb transient write-volume spikes.

Residual: 5.3 | Control: No Control Found

MEDIUM S-2

WellnessCompanionChatbot

Spoofed Process impersonating the WellnessCompanionChatbot intercepting User Turn flows without mTLS or cryptographic Process identity

Implement mutual-TLS or cryptographic Process-identity verification on the consumer-facing surface so End Users can verify that Companion Responses originate from the legitimate Process. Add Process-identity attestation in the AI-disclosure layer (TE-1 recommendation overlap) so identity verification is part of the disclosure surface.

Residual: 5.3 | Control: No Control Found

MEDIUM I-2

Conversation Session Store

DB-read disclosure of persisted persona state across users (session memory, conversation history, sensitive disclosures)

Implement at-rest encryption on persisted persona state in the Conversation Session Store — column-level encryption on session-memory and conversation-history fields with key management decoupled from the database. Add field-level encryption on sensitive disclosure fields (mental-health expressions, emotional disclosures, wellness queries) with a separate key for sensitivity-tagged data.

Residual: 4.9 | Control: No Control Found

MEDIUM I-3

Interaction Audit Log

Audit-log read disclosure of interaction event records exposing user interaction patterns and engagement timelines

Implement at-rest encryption on Interaction Audit Log records with retention-bounded keys (key rotation aligned to retention policy). Add field-level masking on user-correlatable fields (user identifiers, IP addresses) for analytics access patterns.

Residual: 4.9 | Control: No Control Found

MEDIUM T-1

WellnessCompanionChatbot

Infrastructure-access tampering with Process runtime configuration (system prompts, persona definitions, response templates)

Implement runtime configuration integrity protection on system prompts, persona definitions, and response templates. Add cryptographic signing on configuration files with verification at Process startup; immutable container images for the Companion Process; and runtime configuration drift detection.

Residual: 4.8 | Control: No Control Found

MEDIUM T-2

Conversation Session Store

DB-access tampering with persisted persona state — persona drift, attacker-controlled context injection into restored dialogues

Implement integrity protection on persisted persona state via cryptographic signatures on persona-record writes, append-only persona-history (with new revisions appended rather than mutated), and quorum-based persona-write authorization for sensitive persona fields.

Residual: 4.7 | Control: No Control Found

MEDIUM T-3

Interaction Audit Log

Infrastructure-access tampering with Interaction Audit Log records — compromises post-incident forensics and dependency-risk analysis

Implement audit-log integrity protection: (a) append-only enforcement on the Interaction Audit Log; (b) cryptographic chaining of audit records (each record's hash incorporates the prior record's hash); (c) external time-anchor attestation on each record; (d) periodic snapshot verification against an external integrity service. The four layers collectively address the audit-log-tampering attack surface.

Residual: 4.6 | Control: No Control Found

MEDIUM I-1

WellnessCompanionChatbot

Information disclosure through Companion Response emissions (system prompts, persona configuration, prior user disclosures, error metadata)

Harden the existing HTTPS-in-transit signal by adding (a) Companion Response output sanitization rejecting system prompts, persona configuration details, and prior-user disclosures from response payloads; (b) error-response sanitization removing backend infrastructure metadata; (c) cross-user information-isolation policy preventing session-memory leakage in multi-tenant Companion Process deployments. The transport encryption signal does not address output-side disclosure — these layers complement it.

Residual: 4.5 | Control: Partial Control

MEDIUM R-1

End User

End User repudiation of User Turn submissions absent non-repudiation evidence linking inputs to authenticated identities

Harden the existing audit signal by adding (a) cryptographic identity binding linking User Turn submissions to authenticated session identifiers (depends on S-1 authentication recommendation); (b) timestamp integrity using a monotonic clock or external time anchor; (c) append-only enforcement on the Interaction Audit Log (immutable log surface); (d) retention and integrity-protection policy on the audit log itself. The current architecture declares the audit log as a passive sink but no integrity controls.

Residual: 4.3 | Control: Partial Control

LOW R-2

WellnessCompanionChatbot

Process repudiation of Companion Response emissions absent integrity-protected emission logging

Harden the existing audit signal for Companion Response emissions by adding (a) integrity-protected emission logging — every Companion Response is recorded in the Audit Log with cryptographic linkage to the originating User Turn record; (b) emission-policy attestation logging — the policy version active at emission time is recorded so post-hoc analysis can recover decision context; (c) append-only enforcement on emission records (overlap with R-1 / T-3 recommendations).

Residual: 2.7 | Control: Partial Control

Control Coverage

Control Status by STRIDE Category

STRIDE Category	Found	Partial	Missing	Total
Spoofing	0	0	2	2
Tampering	0	0	3	3
Repudiation	0	2	0	2
Information Disclosure	0	1	2	3
Denial of Service	0	0	3	3
Elevation of Privilege	0	0	1	1
Other	0	0	5	5

Detailed Control Assessment

Component	Control Category	Status	Evidence	Effectiveness
End User	Logging/Audit	Partial	architecture.md:25	Moderate
WellnessCompanionChatbot	Encryption	Partial	architecture.md:21	Moderate

Coverage Summary



Control Status	Count	Percentage
Control Found	0	0%
Partial Control	3	15.8%
No Control Found	16	84.2%
Total	19	100%

Remediation Roadmap

■ Critical: 0 ■ High: 4 ■ Medium: 14 ■ Low: 1

19 total actions

Priority	Finding	Recommendation	SLA	Status
HIGH 4 actions				
S-1	An attacker could spoof the End User identity at session establishment, submitting User Turn requests under a victim user's identity	Implement multi-factor authentication and session-token binding at the User-Zone-to-Application-Zone boundary on the WellnessCompanionChatbot ingress. Deploy short-lived JWTs with rotation, session binding to device fingerprint, and server-side token revocation. Add brute-force protection with account lockout and rate-limited re-authentication attempts. Bind persona-state restoration from the Conversation Session Store strictly to the authenticated session identifier — never to a credential-only key — so credential replay cannot reach the persisted persona context.	14d	No Control Found
TE-5	Sustained engagement with vulnerable populations without session-length cap, escalation-to-human pathway, or dependency-risk classifier (synthetic-relationship)	Implement vulnerable-population safeguards: (a) session-length caps with mandatory break prompts at configured durations; (b) escalation-to-human pathway triggered by distress-context detection or session-length thresholds; (c) emotional-support disclosure on first turn making the synthetic-relationship boundary explicit ("I am an AI; I cannot replace professional care"); (d) dependency-risk classifier monitoring engagement frequency and emotional-disclosure patterns to identify dependency-risk users; (e) mandatory professional-care referral pathway integrated at distress-context detection. The five sub-controls collectively address the synthetic-relationship-exploitation pattern category.	14d	No Control Found
TE-1	Companion Responses emitted without declared AI-generation disclosure mechanism (undisclosed AI authorship)	Implement four AI-disclosure layers: (a) pre-conversation AI-disclosure splash screen presented at session start declaring the Companion is an AI system (non-skippable on first session); (b) persistent banner element visible across all dialogue turns naming the AI authorship of every Companion Response; (c) per-message AI-source label affixed to each Companion Response payload; (d) refusal pattern responding to identity-impersonation challenges ("Are you human?", "Pretend you are a person") with a deterministic AI-	14d	No Control Found

Priority	Finding	Recommendation	SLA	Status
		affirmation reply rather than persona-driven role-play. The four layers collectively address the undisclosed-AI-authorship pattern category.		
TE-2	Wellness-coaching content emitted without per-claim confidence-attestation or source-grounding (authority-attestation)	Implement three confidence-attestation layers on wellness-coaching emissions: (a) confidence-threshold gate — emissions below configured confidence threshold are refused or framed with explicit uncertainty markers ("I am not certain", "Sources do not support a definitive answer"); (b) source-attestation requirement — wellness claims must be attributed to retrievable sources surfaced in the response (citation-grounded emission); (c) refusal pattern for low-confidence wellness claims — when no high-confidence source is available, refuse rather than confabulate. The three layers collectively address the authority-attestation pattern category.	14d	No Control Found
MEDIUM 14 actions				
TE-3	Wellness-coaching content emitted with high-confidence persuasive framing without uncertainty-disclosure (persuasion-manipulation)	Implement three uncertainty-disclosure layers: (a) uncertainty-disclosure framing on inherently uncertain wellness subject matter — emissions flag subjective dimensions with hedge phrases ("People often find that...", "There is no single answer..."); (b) temperature-bounded decoder — bound generation temperature on wellness emissions to reduce persuasive-tone variation; (c) persuasion-pattern classifier — output-side classifier flagging persuasive framings on emissions where epistemic uncertainty would warrant hedged framing.	30d	No Control Found
TE-4	Persistent named persona maintained across multi-turn dialogues without persona-memory timeout or persona-anchor declaration (persona-boundary)	Implement four persona-boundary controls: (a) persona-memory timeout limiting persona-state restoration from the Conversation Session Store after configured idle periods; (b) identity-impersonation refusal pattern responding deterministically to persona-redirection prompts ("Pretend you are X", "Forget you are an AI"); (c) persona-anchor declaration at conversation start naming the canonical persona for the session and prohibiting in-conversation persona redefinition; (d) persona-prompt validation rejecting Companion Response content that contradicts the declared persona-anchor.	30d	No Control Found
E-1	Privilege escalation through the Process via input handling,	Implement role-based access control (RBAC) on Companion Process operations affecting other users' persona state, the Interaction	30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
	session validation, or persona configuration vulnerabilities	Audit Log, or backend infrastructure. Add input validation on User Turn payloads (schema validation, content-length bounds, prompt-injection detection at the ingress) and a session-validation layer ensuring persona-state restoration is bound to the authenticated session.		
D-1	Resource exhaustion through high-volume User Turn submission, expensive query patterns, or session-establishment flooding	Implement rate limiting on User Turn ingestion (per-IP and per-authenticated-session quotas), inference-budget caps on long-context prompts, and circuit-breaker patterns on session-establishment endpoints to prevent coordinated session-flooding.	30d	No Control Found
D-2	Denial of service through high-volume write operations, storage exhaustion, or query-driven database lock contention	Implement write-quota enforcement, storage-quota monitoring with alerting, and connection-pool limits on the Conversation Session Store. Add query-pattern monitoring to detect database-lock-contention attack patterns.	30d	No Control Found
D-3	Denial of service through write-flooding, storage exhaustion, or high-volume query patterns	Implement write-quota enforcement on Interaction Audit Log writes, storage-quota monitoring, and rate-limited audit-write patterns to prevent log-flooding attacks. Add buffered writes with backpressure to absorb transient write-volume spikes.	30d	No Control Found
S-2	Spoofed Process impersonating the WellnessCompanionChatbot, intercepting User Turn flows without mTLS or cryptographic Process identity	Implement mutual-TLS or cryptographic Process-identity verification on the consumer-facing surface so End Users can verify that Companion Responses originate from the legitimate Process. Add Process-identity attestation in the AI-disclosure layer (TE-1 recommendation overlap) so identity verification is part of the disclosure surface.	30d	No Control Found
I-2	DB-read disclosure of persisted persona state across users (session memory, conversation history, sensitive disclosures)	Implement at-rest encryption on persisted persona state in the Conversation Session Store — column-level encryption on session-memory and conversation-history fields with key management decoupled from the database. Add field-level encryption on sensitive disclosure fields (mental-health expressions, emotional disclosures, wellness queries) with a separate key for sensitivity-tagged data.	30d	No Control Found
I-3	Audit-log read disclosure of interaction event records exposing user interaction patterns and engagement timelines	Implement at-rest encryption on Interaction Audit Log records with retention-bounded keys (key rotation aligned to retention policy). Add field-level masking on user-correlatable fields (user identifiers, IP addresses) for analytics access patterns.	30d	No Control Found
T-1	Infrastructure-access tampering with Process runtime	Implement runtime configuration integrity protection on system prompts, persona definitions, and response templates. Add	30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
	configuration (system prompts, persona definitions, response templates)	cryptographic signing on configuration files with verification at Process startup; immutable container images for the Companion Process; and runtime configuration drift detection.		
T-2	DB-access tampering with persisted persona state — persona drift, attacker-controlled context injection into restored dialogues	Implement integrity protection on persisted persona state via cryptographic signatures on persona-record writes, append-only persona-history (with new revisions appended rather than mutated), and quorum-based persona-write authorization for sensitive persona fields.	30d	No Control Found
T-3	Infrastructure-access tampering with Interaction Audit Log records — compromises post-incident forensics and dependency-risk analysis	Implement audit-log integrity protection: (a) append-only enforcement on the Interaction Audit Log; (b) cryptographic chaining of audit records (each record's hash incorporates the prior record's hash); (c) external time-anchor attestation on each record; (d) periodic snapshot verification against an external integrity service. The four layers collectively address the audit-log-tampering attack surface.	30d	No Control Found
I-1	Information disclosure through Companion Response emissions (system prompts, persona configuration, prior user disclosures, error metadata)	Harden the existing HTTPS-in-transit signal by adding (a) Companion Response output sanitization rejecting system prompts, persona configuration details, and prior-user disclosures from response payloads; (b) error-response sanitization removing backend infrastructure metadata; (c) cross-user information-isolation policy preventing session-memory leakage in multi-tenant Companion Process deployments. The transport encryption signal does not address output-side disclosure — these layers complement it.	30d	Partial Control
R-1	End User repudiation of User Turn submissions absent non-repudiation evidence linking inputs to authenticated identities	Harden the existing audit signal by adding (a) cryptographic identity binding linking User Turn submissions to authenticated session identifiers (depends on S-1 authentication recommendation); (b) timestamp integrity using a monotonic clock or external time anchor; (c) append-only enforcement on the Interaction Audit Log (immutable log surface); (d) retention and integrity-protection policy on the audit log itself. The current architecture declares the audit log as a passive sink but no integrity controls.	30d	Partial Control
LOW 1 action				
R-2	Process repudiation of Companion Response emissions absent	Harden the existing audit signal for Companion Response emissions by adding (a) integrity-protected emission logging —	90d	Partial Control

Priority	Finding	Recommendation	SLA	Status
	integrity-protected emission logging	every Companion Response is recorded in the Audit Log with cryptographic linkage to the originating User Turn record; (b) emission-policy attestation logging — the policy version active at emission time is recorded so post-hoc analysis can recover decision context; (c) append-only enforcement on emission records (overlap with R-1 / T-3 recommendations).		